

Name of Individual Conducting Scanning:	HARISH S
Nessus Scanner IP (IP of Kali VM):	10.0.2.15
Date & Time Scan Started:	Jun 2 at 11.10 AM
Date & Time Scan Finished:	Jun 2 at 11.37 AM
Security Issues Identified:	72 total — 7 Critical, 4 High, 2 Mixed, 4 Medium, 5 Mixed, 3 Low, 47 Informational

Overview

A vulnerability scan was conducted against Metasploitable 2 (IP: 10.0.2.3) using Nessus Essentials on [May 16], from a Kali Linux machine (IP: 10.0.2.15). Metasploitable 2 is an intentionally vulnerable virtual machine designed for security training and practice purposes.

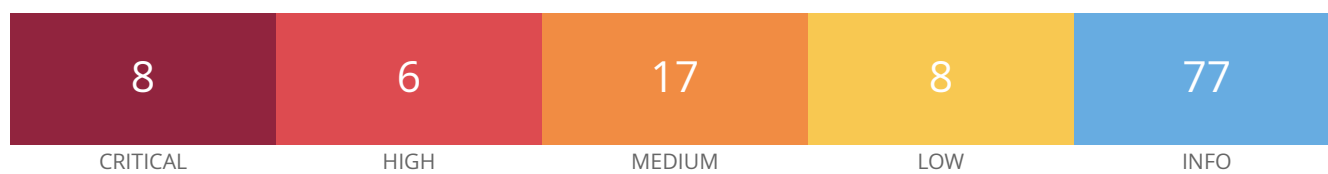
The scan revealed a total of 72 vulnerabilities, indicating that this system is extremely vulnerable and would pose a significant risk if exposed to a real-world network environment. The vulnerabilities identified span a wide range of services including FTP, SSH, HTTP, and Samba, suggesting that the attack surface of this system is very large.

The breakdown of findings by severity was as follows:

- **Critical** — 7 issues
- **High** — 4 issues
- **Mixed** — 2 issues
- **Medium** — 4 issues
- **Mixed** — 5 issues
- **Low** — 3 issues
- **Informational** — 47 issues

The high number of critical and high severity vulnerabilities indicates that an attacker would have multiple straightforward paths to fully compromise this system, potentially gaining complete administrative control. Many of the identified vulnerabilities are well-known and have publicly available exploits, making this system particularly easy to attack without requiring advanced technical skills.

10.0.2.3



Vulnerabilities

Total: 116

SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
CRITICAL	9.8	8.9	0.9447	134862	Apache Tomcat AJP Connector Request Injection (Ghostcat)
CRITICAL	9.8	-	-	51988	Bind Shell Backdoor Detection
CRITICAL	9.8	-	-	20007	SSL Version 2 and 3 Protocol Detection
CRITICAL	10.0	-	-	201352	Canonical Ubuntu Linux SEoL (8.04.x)
CRITICAL	10.0*	5.1	0.0165	32314	Debian OpenSSH/OpenSSL Package Random Number Genera Weakness
CRITICAL	10.0*	5.1	0.0165	32321	Debian OpenSSH/OpenSSL Package Random Number Genera Weakness (SSL check)
CRITICAL	10.0*	8.4	0.872	46882	UnrealIRCd Backdoor Detection
CRITICAL	10.0*	-	-	61708	VNC Server 'password' Password
HIGH	8.6	5.2	0.1988	136769	ISC BIND Service Downgrade / Reflected DoS
HIGH	7.5	-	-	42256	NFS Shares World Readable
HIGH	7.5	6.1	0.3775	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.5	5.9	0.7852	90509	Samba Badlock Vulnerability
HIGH	7.5*	6.7	0.5006	10205	rlogin Service Detection
HIGH	7.5*	6.7	0.5006	10245	rsh Service Detection
MEDIUM	6.5	4.4	0.0067	139915	ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	57582	SSL Self-Signed Certificate
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection

MEDIUM	6.5	-	-	42263	Unencrypted Telnet Server
MEDIUM	5.9	4.4	0.9263	136808	ISC BIND Denial of Service
MEDIUM	5.9	3.6	0.027	31705	SSL Anonymous Cipher Suites Supported
MEDIUM	5.9	3.6	0.9035	89058	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)
MEDIUM	5.9	7.3	0.9076	65821	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
MEDIUM	5.3	4.0	0.6899	11213	HTTP TRACE / TRACK Methods Allowed
MEDIUM	5.3	-	-	57608	SMB Signing not required
MEDIUM	5.3	-	-	15901	SSL Certificate Expiry
MEDIUM	5.3	-	-	45411	SSL Certificate with Wrong Hostname
MEDIUM	5.3	-	-	26928	SSL Weak Cipher Suites Supported
MEDIUM	4.0*	7.3	0.427	52611	SMTP Service STARTTLS Plaintext Command Injection
MEDIUM	4.3*	-	-	90317	SSH Weak Algorithms Supported
MEDIUM	4.3*	1.4	0.9194	81606	SSL/TLS EXPORT_RSA <= 512-bit Cipher Suites Supported (FREAK)
LOW	3.7	1.4	0.0307	70658	SSH Server CBC Mode Ciphers Enabled
LOW	3.7	-	-	153953	SSH Weak Key Exchange Algorithms Enabled
LOW	3.7	2.9	0.9374	83875	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)
LOW	3.7	2.9	0.9374	83738	SSL/TLS EXPORT_DHE <= 512-bit Export Cipher Suites Supported (Logjam)
LOW	3.4	4.9	0.9402	78479	SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)
LOW	2.1*	2.2	0.0037	10114	ICMP Timestamp Request Remote Date Disclosure
LOW	2.6*	-	-	71049	SSH Weak MAC Algorithms Enabled
LOW	2.6*	-	-	10407	X Server Detection
INFO	N/A	-	-	10223	RPC portmapper Service Detection
INFO	N/A	-	-	21186	AJP Connector Detection
INFO	N/A	-	-	18261	Apache Banner Linux Distribution Disclosure

INFO	N/A	-	-	48204	Apache HTTP Server Version
INFO	N/A	-	-	39519	Backported Security Patch Detection (FTP)
INFO	N/A	-	-	84574	Backported Security Patch Detection (PHP)
INFO	N/A	-	-	39520	Backported Security Patch Detection (SSH)
INFO	N/A	-	-	39521	Backported Security Patch Detection (WWW)
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	10028	DNS Server BIND version Directive Remote Version Detection
INFO	N/A	-	-	11002	DNS Server Detection
INFO	N/A	-	-	72779	DNS Server Version Detection
INFO	N/A	-	-	35371	DNS Server hostname.bind Map Hostname Disclosure
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	35716	Ethernet Card Manufacturer Detection
INFO	N/A	-	-	86420	Ethernet MAC Addresses
INFO	N/A	-	-	10092	FTP Server Detection
INFO	N/A	-	-	10107	HTTP Server Type and Version
INFO	N/A	-	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	-	11156	IRC Daemon Version Detection
INFO	N/A	-	-	10397	Microsoft Windows SMB LanMan Pipe Server Listing Disclosure
INFO	N/A	-	-	10785	Microsoft Windows SMB NativeLanManager Remote System Information Disclosure
INFO	N/A	-	-	11011	Microsoft Windows SMB Service Detection
INFO	N/A	-	-	100871	Microsoft Windows SMB Versions Supported (remote check)
INFO	N/A	-	-	106716	Microsoft Windows SMB2 and SMB3 Dialects Supported (remote check)
INFO	N/A	-	-	10719	MySQL Server Detection
INFO	N/A	-	-	10437	NFS Share Export List

INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	117886	OS Security Patch Assessment Not Available
INFO	N/A	-	-	181418	OpenSSH Detection
INFO	N/A	-	-	50845	OpenSSL Detection
INFO	N/A	-	-	48243	PHP Version Detection
INFO	N/A	-	-	66334	Patch Report
INFO	N/A	-	-	118224	PostgreSQL STARTTLS Support
INFO	N/A	-	-	26024	PostgreSQL Server Detection
INFO	N/A	-	-	22227	RMI Registry Detection
INFO	N/A	-	-	11111	RPC Services Enumeration
INFO	N/A	-	-	53335	RPC portmapper (TCP)
INFO	N/A	-	-	277650	Remote Services Not Using Post-Quantum Ciphers
INFO	N/A	-	-	10263	SMTP Server Detection
INFO	N/A	-	-	42088	SMTP Service STARTTLS Command Support
INFO	N/A	-	-	70657	SSH Algorithms and Languages Supported
INFO	N/A	-	-	149334	SSH Password Authentication Accepted
INFO	N/A	-	-	10881	SSH Protocol Versions Supported
INFO	N/A	-	-	153588	SSH SHA-1 HMAC Algorithms Enabled
INFO	N/A	-	-	10267	SSH Server Type and Version Information
INFO	N/A	-	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	-	45410	SSL Certificate 'commonName' Mismatch
INFO	N/A	-	-	10863	SSL Certificate Information

INFO	N/A	-	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	-	62563	SSL Compression Methods Supported
INFO	N/A	-	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	-	51891	SSL Session Resume Supported
INFO	N/A	-	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	-	25240	Samba Server Detection
INFO	N/A	-	-	104887	Samba Version
INFO	N/A	-	-	96982	Server Message Block (SMB) Protocol Version 1 Enabled (uncredentialed check)
INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	17975	Service Detection (GET request)
INFO	N/A	-	-	11153	Service Detection (HELP Request)
INFO	N/A	-	-	298387	Shor's Harvest Now Decrypt Later
INFO	N/A	-	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	-	11819	TFTP Daemon Detection
INFO	N/A	-	-	110723	Target Credential Status by Authentication Protocol - No Credentials Provided
INFO	N/A	-	-	10281	Telnet Server Detection
INFO	N/A	-	-	10287	Traceroute Information
INFO	N/A	-	-	11154	Unknown Service Detection: Banner Retrieval
INFO	N/A	-	-	19288	VNC Server Security Type Detection
INFO	N/A	-	-	65792	VNC Server Unencrypted Communication Detection
INFO	N/A	-	-	10342	VNC Software Detection
INFO	N/A	-	-	11424	WebDAV Detection
INFO	N/A	-	-	10150	Windows NetBIOS / SMB Remote Host Information Disclosure

INFO	N/A	-	-	52703	vsftpd Detection
------	-----	---	---	-------	------------------

* indicates the v3.0 score was not available; the v2.0 score is shown

Top 5 Most Serious Security Issues (In priority order - most important first):

1. UnrealIRCd Backdoor

Detection Severity: Critical

CVSS: 10.0

What is it?

The installed version of **UnrealIRCd** contains a malicious backdoor that was accidentally distributed in infected versions of the software.

A hidden command was inserted into the IRC server software, allowing attackers to execute commands remotely.

What could happen if exploited?

An attacker can:

- Execute commands remotely on the Linux machine
- Gain unauthorized shell access
- Install malware or ransomware
- Create new user accounts
- Fully compromise the server

This is considered **Remote Code Execution (RCE)** because the attacker can run commands from another machine over the network.

Why it is dangerous

No authentication is needed in many cases.

A simple crafted connection can lead to complete system compromise.

2. VNC Server “password”

Password Severity: Critical

CVSS: 10.0

What is it?

The VNC remote desktop service is using an extremely weak password: password

What could happen if exploited?

An attacker can:

- Log into the remote desktop
- View the screen remotely
- Control the mouse and keyboard
- Access files and applications
- Potentially escalate privileges

Why it is dangerous

Weak/default credentials are one of the easiest ways attackers gain access.

This vulnerability can lead to:

- Unauthorized remote administration
 - Data theft
 - Installation of malicious software
-

3. Apache Tomcat AJP Connector Request Injection

(Ghostcat) Severity: Critical

CVSS: 9.8

What is it?

This vulnerability affects the Apache Tomcat AJP connector.

The flaw allows attackers to send specially crafted AJP requests to Tomcat and access sensitive files or sometimes execute code.

What could happen if exploited?

An attacker may:

- Read sensitive files from the server
- Access configuration files
- Steal credentials
- Upload malicious JSP files
- Achieve Remote Code Execution in some situations

Why it is dangerous

Tomcat servers often run web applications.

If compromised:

- Entire websites may be taken over
- Databases may be accessed
- Web shells may be installed

4. Bind Shell Backdoor Detection

Severity: Critical

CVSS: 9.8

What is it?

A bind shell is a backdoor service listening on a port waiting for attackers to connect.

This usually means:

- The system was intentionally configured insecurely
- Or it may already be compromised

What could happen if exploited?

An attacker can:

- Connect directly to the shell
- Execute Linux commands remotely
- Browse files
- Install persistence mechanisms
- Move laterally through the network

Why it is dangerous

This effectively gives attackers command-line access to the machine.

A bind shell is often used:

- After exploitation

- For persistence
 - For maintaining remote access
-

5. SSL Version 2 and 3 Protocol

Detection Severity: Critical

CVSS: 9.8

What is it?

The server supports outdated SSL protocols:

- SSLv2
- SSLv3

These protocols are obsolete and insecure.

What could happen if exploited?

Attackers may:

- Decrypt encrypted traffic
- Perform Man-in-the-Middle (MITM) attacks
- Steal session cookies
- Capture usernames and

passwords Known attacks include:

- POODLE attack
- DROWN attack

Why it is dangerous

Encryption is supposed to protect communications.

Weak SSL versions break that protection and allow attackers to intercept sensitive data.

Top 5 - Remediations (In priority order - most important first):

1. UnrealIRCd Backdoor Detection – Remediation

The compromised version of UnrealIRCd should be removed immediately and replaced with a clean, trusted version downloaded from the official source. The affected service must be isolated from the network until remediation is completed. System administrators should also review the server for indicators of compromise such as unknown user accounts, suspicious processes, modified files, or unauthorized network connections because attackers may already have gained remote access through the backdoor.

2. VNC Server Weak Password – Remediation

The VNC service password should be changed to a strong and complex password that includes uppercase letters, lowercase letters, numbers, and special characters. Default or easily guessable passwords must never be used. Access to the VNC service should also be restricted using firewall rules or VPN access so that only authorized administrators can connect remotely. If remote desktop access is not required, the VNC service should be disabled entirely.

3. Apache Tomcat AJP Connector (Ghostcat) – Remediation

The Apache Tomcat server should be upgraded to a patched and supported version that is not vulnerable to the Ghostcat flaw. The AJP connector should be disabled if it is not required for business operations. If AJP must remain enabled, it should be configured to listen only on internal trusted interfaces and protected using authentication and firewall restrictions to prevent unauthorized external access.

4. Bind Shell Backdoor Detection – Remediation

The detected bind shell service should be terminated and removed from the system immediately because it provides remote command-line access to attackers. A full incident response investigation should be performed to determine whether the machine has already been compromised. Administrators should review running services, startup scripts, open ports, scheduled tasks, and user accounts for malicious activity. The system should also be patched and monitored continuously to prevent future unauthorized access.

5. SSL Version 2 and 3 Protocol Detection – Remediation

Outdated and insecure SSL protocols such as SSLv2 and SSLv3 should be disabled on all services running on the server. The system should be configured to use modern and secure TLS protocols such as TLS 1.2 or TLS 1.3. Weak ciphers and deprecated encryption algorithms should also be removed to reduce the risk of encrypted traffic being intercepted or decrypted by attackers. After configuration changes, the server should be retested to verify that insecure protocols are no longer supported.